

GUÍA METODOLÓGICA: KIT ENCUESTA INTEGRAL CIBERSEGURIDAD

Instrucciones Detalladas de Administración y Análisis

Versión: 2.0 | **Fecha:** Enero 2026 | **Audiencia:** Consultores, CISOs, Auditores

Tiempo de administración: 2-3 horas (incluye aplicación + análisis inicial)

1. PROPÓSITO Y ALCANCE DE LA ENCUESTA

1.1 Objetivo General

Esta encuesta integral evalúa la **madurez de ciberseguridad** de una organización mediante:

- Mapeo de 75+ preguntas a estándares internacionales (MAGERIT v3, ENS RD 311/2022, NIS2, NIST CSF, ISO 27001)
- Cuantificación de estado actual en 10 bloques temáticos (gobernanza, riesgos, métricas, vulnerabilidades, SIEM, formación, resiliencia, cumplimiento, incidentes, madurez)
- Generación de **Índice Global de Madurez (IGM)** L0-L5 CMM
- Identificación de **brecha normativa** vs. NIS2/ENS/ISO 27001
- Priorización de inversiones mediante **análisis ROI y ALE**

1.2 Público Objetivo

Respondentes primarios: CISO, Responsable Seguridad, CTO, Director TI

Respondentes secundarios: SOC Manager, Gestor Riesgos, Compliance Officer, DPO

Audiencia de resultados: Junta Directiva, C-Suite, Stakeholders del Negocio

1.3 Tiempo Requerido

Fase	Tiempo
Preparación (briefing equipo)	30 min
Cumplimentación encuesta (completa)	45-60 min
Análisis respuestas (automático + manual)	60-90 min
Generación informe ejecutivo	60 min
Sesión feedback + plan acción	90 min
Total	3.5-4 horas

2. PRE-ENCUESTA: PREPARACIÓN

2.1 Identificación de Respondentes

Grupo mínimo recomendado: 3-5 personas

- CISO o Responsable Seguridad (coordinador)
- Manager operaciones TI / Infraestructura
- Manager aplicaciones / desarrollo

- Responsable cumplimiento / legal
- Responsable RR.HH. (para sección capacitación)

Opcionalmente: Auditores internos, Proveedores clave seguridad

2.2 Briefing Pre-Encuesta

Antes de aplicar, facilite sesión 30 min:

Contenido recomendado:

1. **Contexto:** Propósito diagnóstico (no auditoría punitiva), confidencialidad de resultados
2. **Metodología:** Explicar escala Likert L1-L5, énfasis en "honestidad > perfeccionismo"
3. **Tiempo:** Confirmar disponibilidad y plazo de entrega
4. **Dudas:** Aclarar términos técnicos (MAGERIT MAR, FAIR, CMM)
5. **Outputs esperados:** Informe ejecutivo, recomendaciones, plan de acción

Mensaje clave: *"Esta encuesta busca identificar oportunidades de mejora, no certificar cumplimiento."*

2.3 Preparación Datos Base

Antes de iniciar, reúna:

- **Documentación:** Política seguridad, plan DR, últimos reportes auditoría ENS/ISO 27001
- **Incidentes históricos:** Número y tipo últimos 12-24 meses
- **Inventario activos:** CMDB actual o lista sistemas críticos
- **Presupuesto seguridad:** Gastos últimos 2 años, proyecciones
- **Equipo:** Tamaño, roles TI/seguridad

3. ADMINISTRACIÓN DE LA ENCUESTA

3.1 Modos de Administración

Opción A: Digital (Recomendado)

Herramientas: Google Forms / Microsoft Forms / Qualtrics / Jotform

Ventajas:

- Respuestas automáticas validadas (escala 1-5, required fields)
- Análisis automático descriptivo (medias, distribuciones)
- Exportación a Excel para cálculos personalizados
- Trazabilidad (quién respondió, cuándo)

Pasos:

1. Crear formulario digital replicando estructura 01-encuesta-integral.md
2. Añadir validaciones: cada pregunta requerida, rango 1-5
3. Distribuir link a respondentes, plazo 5 días
4. Recordatorios día 2 y 4

Opción B: Sesión Colaborativa (Recomendado si alto desacuerdo interno)

Dinámica: Facilitador + equipo 4h en sala

Ventajas:

- Debate constructivo, consensus-building
- Aclaraciones inmediatas de dudas
- Contexto cualitativo capturado
- Buy-in ejecutivo por participación

Formato:

1. Bloque 1-2 (30 min): Gobernanza + Riesgos MAR
2. Pausa (10 min)
3. Bloque 3-5 (60 min): Métricas, Vulnerabilidades, SIEM
4. Pausa (10 min)
5. Bloque 6-10 (60 min): Capacitación, Resiliencia, Cumplimiento, Madurez
6. Síntesis (20 min): Consenso scores, discusiones abiertas

Opción C: Mixta (Asincrónico + Síntesis)

- Respondentes rellenan individualmente (digital, 3 días)
- Sesión 90 min facilitador + CISO: revisión discrepancias, consenso final
- Reporte consolidado

3.2 Instrucciones al Respondente

Antes de empezar:

1. Tiempo disponible: 45-60 min sin interrupciones
 2. Responda basándose en situación ACTUAL, no aspiracional
 3. Si "no sabe", use observación campo para comentar
 4. Escala Likert interpretación:
 - **1:** No existe, no documentado, reaccionamos ad hoc
 - **2:** Iniciado, existe parcialmente, inconsistencias
 - **3:** Documentado, procedimientos formales, aplicación consistente
 - **4:** Medido, monitoreado, mejora continua en marcha
 - **5:** Automatizado, predictivo, líder sectorial
1. Observaciones: Campo libre para añadir contexto crítico (máx. 1-2 líneas)

3.3 Cierre y Validación

Al recibir respuestas:

1. Revisar completitud (no respuestas en blanco)
2. Detectar inconsistencias grosseras (ej. "L5 SIEM" pero "L1 gestión vulnerabilidades")
3. Follow-up: contactar respondente si duda interpretación

Control calidad:

- % respuestas completas > 95%

- Desviación estándar scores por bloque < 1.5 (si grupo respondió junto)
- Observaciones explican puntuaciones bajas

4. ANÁLISIS DE RESPUESTAS

4.1 Cálculo del Índice Global de Madurez (IGM)

Fórmula:

$$\text{IGM} = (\sum \text{puntuaciones todas preguntas}) / (\text{Número preguntas} \times 5) \times 100$$

Resultado: 0-100% escala, convertible a L1-L5 CMM

Conversión a CMM Level:

- **0-20%:** L1 Inicial (Reactividad)
- **21-40%:** L2 Básico (Documentación inconsistente)
- **41-60%:** L3 Repetible (Procesado, consistente)
- **61-80%:** L4 Gestionado (Optimización)
- **81-100%:** L5 Optimizado (Adaptativo, predictivo)

4.2 Análisis por Bloque

Para cada uno de 10 bloques: Calcular media ponderada

Bloque	Peso	Fórmula
1. Gobernanza	15%	Media preguntas 1.1, 1.2
2. Gestión Riesgos MAGERIT	20%	Media MAR.1-4 (8 preguntas)
3. Indicadores/Métricas	10%	Media 3.1-3.3 (7 preguntas)
4. Vulnerabilidades/Pentest	12%	Media 4.1-4.3 (9 preguntas)
5. SIEM	12%	Media 5.1-5.4 (12 preguntas)
6. Capacitación	8%	Media 6.1-6.3 (9 preguntas)
7. Resiliencia/BCP	10%	Media 7.1-7.4 (10 preguntas)
8. Cumplimiento	8%	Media 8.1-8.4 (10 preguntas)
9. Incidentes	3%	Media 9.1-9.3 (6 preguntas)
10. Madurez General	2%	Auto-assessment 10.1

IGM ponderado:

$$\text{IGM} = (\sum \text{puntuación_bloque} \times \text{peso}) / 100$$

4.3 Análisis Brecha Normativa

Mapeo NIS2/ENS:

- Cada pregunta mapeada a requisito específico (Art. 21 NIS2, Medida ENS)
- Si respuesta <3 (L1-L2): **Brecha de cumplimiento**
- Calcular % conformidad por requerimiento:

$\text{Conformidad (\%)} = (\text{Preguntas L3+}) / (\text{Total preguntas requisito}) \times 100$

Riesgo regulatorio:

- >80%: Riesgo bajo
- 50-80%: Riesgo moderado → Plan acción 90 días
- <50%: Riesgo alto → Escalación inmediata

4.4 Análisis Fortalezas y Debilidades

Identificar:

1. **Top 3 fortalezas:** Bloques con IGM >65%
2. **Top 3 debilidades:** Bloques con IGM <50%
3. **Asimetrías críticas:** Ej. Identify 70% pero Respond 40% (matriz NIST desbalanceada)

5. CUANTIFICACIÓN FINANCIERA (FAIR/ALE)

5.1 Conversión Respuestas a ALE (Annualized Loss Exposure)

Utilizar plantilla Excel: **05-template-gim-roi.md**

Inputs:

- Puntuación vulnerabilidades/pentest (Bloque 4) → TEF (Threat Event Frequency)
- Puntuación SIEM/detección (Bloque 5) → Control strength (1 - % alertas detectadas)
- Puntuación salvaguardas MAR (Bloque 2) → Eficacia mitigación
- Impacto activos MAR.1 (valor €) → Loss Magnitude

Salida: ALE anual estimado por categoría riesgo

5.2 Cálculo ROI Inversiones Seguridad

Para cada salvaguarda propuesta:

$\text{ROI (\%)} = (\text{ALE sin control} - \text{ALE con control} - \text{Costo implementation}) / \text{Costo implementation} \times 100$

$\text{Payback period (meses)} = \text{Costo implementation} / (\text{ALE reducción} / 12)$

Decisión: Priorizar inversiones con ROI >50% y payback <24 meses

5.3 Comunicación a Junta: "Riesgo Residual en €"

Riesgo residual anual = ALE (después de salvaguardas propuestas)

Comunicación recomendada:

"Gestión actual genera riesgo residual de €X millones/año.

Inversión €Y propuesta reduce a €Z (reducción X%).

Payback: Z meses."

6. GENERACIÓN DE INFORME EJECUTIVO

6.1 Estructura Reporte Estándar

Documento: 02-narrativa-explicativa.md + 03-mapeo-normativo.md + PPT 06-template-report-ppt.md

Sección	Contenido	Audiencia
Portada	Título, fecha, confidencialidad	Todos
Executive Summary (1 pág)	IGM, top hallazgos, riesgos críticos, recomendaciones top 5	C-Suite
Contexto (1 pág)	Metodología, scope, limitaciones	Técnicos
Resultados (2 pág)	IGM por bloque, matriz fortalezas/debilidades, asimetrías NIST CSF	CISO
Brecha Normativa (1 pág)	% conformidad NIS2/ENS, requisitos críticos incumplidos	Legal/Compliance
Financiero (1 pág)	ALE actual, ROI de top 5 salvaguardas, presupuesto recomendado	CFO
Plan de Acción (1 pág)	Top 10 mejoras, timeline 6-24 meses, propietario, presupuesto	CISO
Detalle Técnico (3-4 pág)	Análisis por bloque, hallazgos específicos, observaciones	Equipo técnico
Apéndices	Mapeo pregunta-normativa, benchmark sectorial, caso de uso	Referencia

6.2 Visualizaciones Recomendadas

Gráfico 1: IGM General (Gauge 0-100%)

IGM: 62% (L3 Repetible)
Target 2026: 75% (L4 Gestionado)

Gráfico 2: Maturity por Bloque (Radar chart)

- Ejes: Gobernanza, MAR, Métricas, Vulns, SIEM, Capacitación, Resiliencia, Cumplimiento, Incidentes
- Línea azul: Actual
- Línea roja: Target 12 meses
- Sombreado: Benchmark sectorial

Gráfico 3: Asimetría NIST CSF (5 bars)

- Identify 68%, Protect 63%, Detect 64%, Respond 55%, Recover 53%
- Benchmark nacional (benchmark-section)
- Identificar debilidad Respond/Recover (crítica para NIS2)

Gráfico 4: Brecha NIS2/ENS (Heatmap)

- Filas: 8 requisitos NIS2 clave
- Columnas: Bloques encuesta
- Color verde/rojo: % conformidad

Gráfico 5: ROI Salvaguardas (Bubble chart)

- X: Costo implementación (€)
- Y: ALE reducción (€)
- Tamaño: Esfuerzo estimado (meses)
- Etiqueta: Nombre salvaguarda
- Línea diagonal: Breakeven ROI 50%

6.3 Redacción Ejecutiva

Tone: Profesional, propositivo, no alarmista

Frases recomendadas:

- "Madurez actual de 62% indica **sólida base** en gobernanza (70%) pero **oportunidades críticas** en respuesta a incidentes (55%)."
- "Inversión de €Y en SIEM y formación reduce ALE de €X a €Z (reducción 40%), con payback 18 meses."
- "Riesgo de incumplimiento NIS2 es **MODERADO** en 3 áreas: gestión cadena suministro, RTO/RPO, notificación 72h."

7. SESIÓN DE FEEDBACK Y PLAN DE ACCIÓN

7.1 Reunión de Presentación de Resultados

Asistentes: CISO, Dirección TI, CFO, Legal, Junta si aplica

Duración: 90 minutos

Agenda:

1. **Contexto** (5 min): Metodología, scope encuesta
2. **Hallazgos IGM** (15 min): Madurez general, top fortalezas/debilidades
3. **Análisis técnico** (20 min): Deep-dive por bloque crítico
4. **Brecha normativa** (10 min): Requisitos NIS2/ENS en riesgo
5. **Financiero** (15 min): ALE, ROI top salvaguardas
6. **Plan acción propuesto** (20 min): Top 10 mejoras, timeline, presupuesto
7. **Q&A y consenso** (5 min)

7.2 Construcción Colaborativa del Plan de Acción

Formato de priorización (workshop 60 min):

Para cada top 10 hallazgo:

1. Título y descripción breve (1 línea)
2. Impacto: Riesgo residual reducción (€)

3. Esfuerzo: Tiempo + recursos (meses, €)
4. Urgencia: Crítico (NIS2 req) / Importante (mejora) / Oportunidad (L5)
5. Propietario asignado
6. Hitos 30/60/90/180/360 días
7. Métricas éxito (nueva puntuación esperada)

Matriz RACI: Responsable, Accountable, Consulted, Informed

7.3 Comunicación Interna

Plantilla comunicado interno (post-feedback):

Asunto: Diagnóstico Ciberseguridad 2026 - Resultados y Plan Mejora

"Hemos completado evaluación integral de madurez ciberseguridad, cuyo objetivo es identificar oportunidades de fortalecimiento alineadas con requisitos regulatorios NIS2 y ENS.

Resultado: Madurez actual 62% (L3 Repetible). Principales fortalezas: Gobernanza, Gestión Riesgos. Oportunidades críticas: Respuesta a incidentes, Resiliencia.

Acciones iniciales (próximos 90 días): Implementación SIEM mejorado, pruebas RTO/RPO, formación avanzada respuesta.

Plan completo disponible: [link acceso restringido]"

8. ITERACIÓN Y SEGUIMIENTO CONTINUO

8.1 Plan de Re-evaluación

Recomendación: Encuesta anual (Q1 o Q4) + mini-assessment trimestral

Cadencia:

- **Anual (completa):** Enero (post-presupuesto), 10 bloques, 75 preguntas
- **Trimestral (ligera):** 15-20 preguntas clave (Bloque 2, 4, 5, 9)
- **Ad-hoc:** Post-incidente o cambio legislativo significativo

8.2 Dashboard de Seguimiento

Herramienta recomendada: Excel/BI (Power BI, Tableau)

Métricas a trackear:

- IGM % trending (target vs. actual)
- Scorecards por bloque (colores rojo/amarillo/verde)
- Top 5 riesgos residuales (€)
- % cumplimiento plan acción (hitos)
- Nuevos incidentes vs. tendencia histórica

Frecuencia: Actualización mensual, reporte Junta trimestral

8.3 Benchmarking Sectorial

Comparativa con pares:

- Sector: Financiero, Energía, Salud, etc.
- Tamaño: >2.500 empleados
- Región: España, Europa

Fuentes de benchmark:

- ISMS Forum Indicador Madurez (publicado anualmente)
- INCIBE 46 métricas (operadores críticos)
- KPMG Benchmark ciber riesgos (privado)
- Gartner Magic Quadrant (herramientas)

9. TROUBLESHOOTING Y FAQ

9.1 Discrepancias Entre Respondentes

Problema: CISO dice "L4 SIEM" pero TI operaciones dice "L2"

Solución:

1. Revisar preguntas específicas (5.1-5.4)
2. Sesión clarificación 30 min: CISO + TI
3. Consenso sobre evidencia (demo SIEM, logs, alertas)
4. Registrar en observaciones cualitativas
5. Usar media de respuestas para análisis (ambos scores válidos)

9.2 "No sabemos la respuesta" (Preguntas técnicas complejas)

Ej.: P2.4.2 "¿Análisis impacto acumulado cascadas de riesgo?"

Solución:

1. Marcar "1" (No existe)
2. Observación: "Sin herramienta formal, análisis ad-hoc"
3. Añadir como oportunidad de mejora (implementar PILAR MAGERIT)

9.3 Organización "Asimétrica" (L5 en parte, L1 en otra)

Ej.: L5 en Gobernanza pero L1 en Respuesta Incidentes

Interpretación: Común en orgs en transformación

- Gobierno establecido pero operaciones rezagadas
- **Brecha de ejecución:** Plan bueno, implementación débil
- **Recomendación:** Acelerar implementación operacional (SIEM, SOC, RTO/RPO)

9.4 "¿Cómo nos comparamos con benchmark?"

Respuesta:

- *Nuestro IGM 62% es típico para empresas medianas españolas en fase de maduración*

- *Comparativa sectorial en Bloque 4 de informe detallado*
- *Recomendación: Objetivo 75% en 12 meses (L4) alineado con NIS2 deadline*

10. CONSIDERACIONES ÉTICAS Y DE CONFIDENCIALIDAD

10.1 Privacidad de Respondentes

- Confidencialidad garantizada: No publicar resultados individuales
- Anonimato: Si múltiples CISOs, agregar datos (no identificar)
- Acceso restringido: Informe final solo Junta + CISO, no publicar externamente

10.2 Honestidad de Respuestas

Riesgo: Inflar scores para "quedar bien"

Mitigación:

1. Mensaje claro en briefing: "Diagnóstico, no auditoría. No hay buenas/malas respuestas."
2. Facilitar sesión anónima si es posible
3. Validar respuestas vs. evidencia (revisar políticas, logs, incidentes históricos)
4. Post-hoc: Si anomalía, conversar con CISO confidencial

10.3 Uso Posterior de Datos

Permitido:

- Informe interno ejecutivo + plan de acción
- Benchmarking interno (año a año)
- Feedback a equipo técnico para mejora continua

Prohibido:

- Compartir con externas (clientes, públicamente) sin consentimiento
- Utilizar para evaluación rendimiento empleados
- Vender datos a terceros

APÉNDICE A: CHECKLIST ADMINISTRACIÓN

- ☐ Identificar respondentes (3-5 personas)
- ☐ Coordinar calendario, disponibilidad
- ☐ Realizar briefing (30 min)
- ☐ Decidir modo: Digital / Colaborativo / Mixto
- ☐ Configurar formulario o sala
- ☐ Distribuir encuesta / Celebrar sesión
- ☐ Recopilar respuestas (validar completitud)
- ☐ Análisis automático (descargar data, plantilla Excel)
- ☐ Cálculo IGM + análisis por bloque
- ☐ Generación informe ejecutivo (borrador)
- ☐ Reunión feedback + construcción plan acción
- ☐ Comunicación interna resultados
- ☐ Seguimiento trimestral (mini-assessment)
- ☐ Re-evaluación anual

© 2026 Guía Metodológica Kit MAGERIT-NIS2-ENS | Consorcio Ciberseguridad

Documento confidencial para uso interno. Requiere actualización anual.